REPORTE TÉCNICO DE SEGURIDAD

Caza pasiva de configuraciones inseguras en entornos reales

Objetivo 1 · Software Seguro | 29 de octubre de 2026

Activo observado: https://www.eternal.com/culture/

Programa de referencia: Eternal Bug Bounty (HackerOne) · Activo *.eternal.com, Tier 3

Modalidad: Observación pasiva mediante Firefox Developer Tools, sin fuzzing, inyecciones, manipulación de solicitudes ni explotación.

1. Resumen ejecutivo

Durante una navegación habitual de la página pública de Eternal se observaron tres cookies de analítica/monitoreo sin las banderas Secure ni HttpOnly, así como una respuesta HTML sin varias cabeceras habituales de endurecimiento de seguridad. La respuesta también identificó la tecnología de proxy Envoy. Estos hechos están respaldados por capturas de Firefox y los valores de cabeceras suministrados.

No se identificaron cookies de autenticación afectadas, exposición de datos sensibles, explotación ni efectos comprobados sobre confidencialidad, integridad o disponibilidad. En consecuencia, el reporte documenta **observaciones reales de configuración**, no una vulnerabilidad explotable confirmada.

2. Alcance y metodología

Se observó únicamente el tráfico generado por la navegación ordinaria a la página pública /culture/. Se revisaron Network → Headers y Storage → Cookies, Local Storage y Session Storage. No se modificaron solicitudes ni se intentó acceder a recursos ajenos.

La política de Eternal identifica *.eternal.com como activo Tier 3 y solicita la cabecera X-Hackerone para tráfico de prueba. Además, excluye de recompensas los problemas aislados de banderas de cookies, buenas prácticas de CSP y divulgación de banners. Por tanto, este documento tiene **propósito académico** y no representa un reporte elegible para recompensa ni acredita cumplimiento de todos los requisitos de prueba del programa.

3. Hallazgo principal: cookies sin atributos de protección

Cookie	Secure	HttpOnly	Contexto
_dd_s	No	No	Monitoreo de sesión (probable)
_ga	No	No	Google Analytics (probable)
_ga_DR416…	No	No	Google Analytics (probable)

La ausencia de Secure implica que el navegador no restringe explícitamente el envío de esas cookies a HTTPS. La ausencia de HttpOnly permite que scripts del mismo origen las consulten. No obstante, para cookies de analítica esta accesibilidad puede ser funcional y no se observó un token de autenticación comprometido.

4. Observaciones adicionales en la respuesta HTTP

Elemento	Evidencia observada	Interpretación
Server	envoy	Identificación de tecnología, sin versión expuesta
HSTS	No presente en la respuesta examinada	Ausencia puntual; no se comprobó estado de precarga ni respuestas alternativas
CSP	No presente en la respuesta examinada	Falta de defensa en profundidad, sin XSS demostrado
X-Content-Type-Options	No presente en la respuesta examinada	Posible oportunidad de hardening
X-Frame-Options	No presente en la respuesta examinada	No se probó clickjacking ni acciones sensibles

5. Evaluación de criticidad — CVSS v3.1

Resultado: 0.0 / None, valoración conservadora de las observaciones sin impacto de seguridad demostrado. Vector ilustrativo: **CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N**.

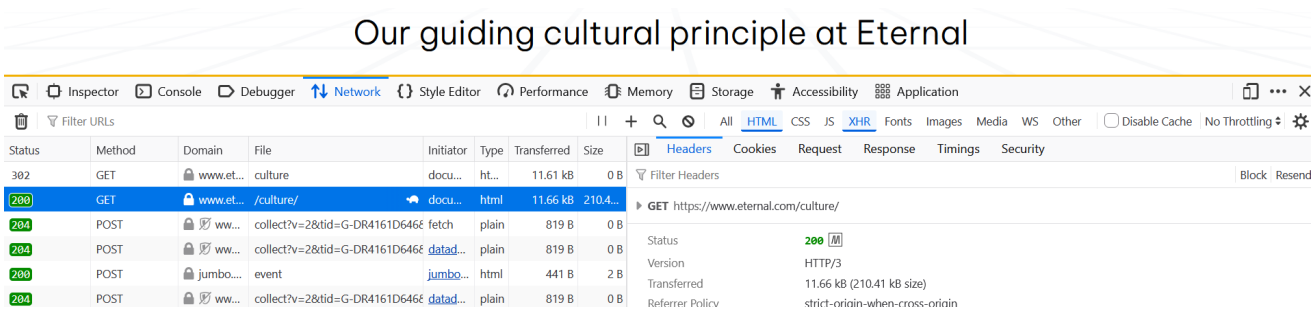
El vector representa un escenario de observación accesible por red sin consecuencias confirmadas sobre C/I/A; no constituye una puntuación de una vulnerabilidad explotable validada. No se asigna una severidad positiva sobre la base exclusiva de la falta de cabeceras o atributos.

6. Recomendaciones

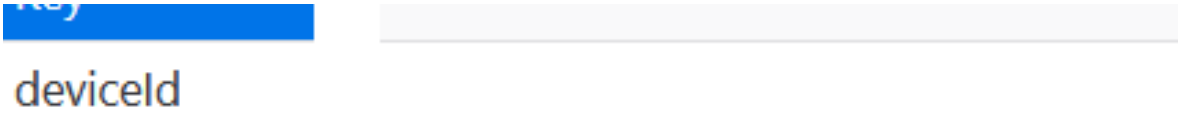
Revisar el propósito de cada cookie y aplicar Secure cuando sea compatible con su uso; reservar HttpOnly para cookies que no necesiten acceso por JavaScript, especialmente tokens de sesión. Evaluar HSTS, CSP, X-Content-Type-Options y políticas anti-embebido en función de la arquitectura, compatibilidad y riesgo. Minimizar cabeceras de infraestructura innecesarias cuando resulte viable.

7. Evidencias

Evidencia A. Petición GET /culture/ en Firefox Network, estado 200 y sección Response Headers.



Evidencia B. Cookies de la página, con valores omitidos deliberadamente. La imagen presenta columnas recortadas para evitar divulgar identificadores.



Evidencia C. Extracto de cabeceras registrado durante la navegación

```
GET /culture/ · HTTP/3 · 200 OK
server: envoy
x-envoy-upstream-service-time: 23
x-served-by-static-gateway: true
content-type: text/html
```

Los encabezados HSTS, CSP, X-Content-Type-Options y X-Frame-Options no figuraban en la lista de respuesta proporcionada. La ausencia se refiere exclusivamente a esa respuesta concreta.

8. Conclusión

El ejercicio cumplió con el procedimiento de inspección pasiva y registró configuraciones observables de un entorno real. El impacto no fue comprobado, por lo que los resultados se clasifican como informativos y el CVSS se mantiene en 0.0. Se recomienda no publicar valores de cookies, tokens o identificadores de sesión en el material académico.

Nota sobre plantilla

Se respetaron las secciones conocidas de la plantilla trabajada en el módulo anterior (resumen ejecutivo, detalles técnicos, CVSS, evidencia/PoC y remediación). No se dispuso del archivo original de esa plantilla para reproducir

exactamente su diseño.

Referencias

FIRST — CVSS v3.1 Specification: https://www.first.org/cvss/v3.1/specification-document

Eternal — Program Policy y Scope: https://hackerone.com/eternal